

# Secure Software Development Process (SSDLC)

Newcoworker LLC · App: New Coworker OAuth (Zoom Marketplace) · Prepared July 2026 · Contact: Brianlane2@gmail.com

## 1. Development workflow (enforced on every change)

---

- **Branch** → **pull request** → **CI** → **review** → **merge**. No direct pushes to `main` ; every change goes through a pull request against `main` .
- **Required CI gates** (GitHub Actions, `.github/workflows/ci.yml`): `lint ( npm run lint )`, full production build, strict TypeScript typecheck ( `tsc --noEmit` ), and the unit test suite with a **100% coverage gate on the core library code** ( `src/lib/**` ).
- **Static analysis on every PR**: GitHub CodeQL ( `javascript-typescript` ) runs on every pull request and push to `main` , plus a weekly scheduled scan (see companion SAST evidence document).
- **Automated code review**: every pull request receives an automated AI security/correctness review (Cursor Bugbot) in addition to CI; merge policy requires every check green and every review thread resolved before merge.
- **Dependency hygiene**: Dependabot alerts are tracked to zero; transitive vulnerabilities are pinned via `package.json overrides` ; a scheduled dependency audit workflow ( `.github/workflows/audit.yml` ) runs independently of feature work.

## 2. Security standards applied to code

---

- **Deny-by-default data layer**: PostgreSQL row-level security enabled on all tables; secret tables run RLS with zero policies (service-role only). Database functions are service-role-only with pinned `search_path` ; a DDL event trigger automatically revokes public execute grants on any new function.
- **Secrets management**: application secrets live in environment configuration, never in the repository. Stored secrets (SSH keys, backup passphrases) are wrapped in application-layer AES-256-GCM encryption; reads fail closed.
- **Zoom-specific handling**: Zoom OAuth tokens are held by Nango (SOC 2 compliant OAuth infrastructure) and are never written to our database; all Zoom API calls are proxied server-side over TLS 1.2+.
- **Transport security**: TLS on every hop (browser → Vercel, app → Supabase, app → Nango → Zoom); webhooks from telecom providers are signature-verified and rate-limited.

## 3. Release & operations

---

- Merges to `main` trigger an ordered deploy pipeline: database migrations (fail loudly on drift), edge function deploys, then production app deploy — a failed migration blocks the app deploy by design.
- Structured telemetry events and alerting cover authentication rejections, signature verification failures, and rate-limit events.
- Data lifecycle controls run as code: configurable retention windows and verified end-user erasure across all content tables.

## 4. CI workflow excerpt (`.github/workflows/ci.yml`)

---

```
name: CI
on:
  pull_request:
  push:
    branches: [main]
jobs:
  quality:      # npm run lint + production build
  typecheck:    # npx tsc --noEmit (strict)
  test:         # unit test suite, 100% coverage gate on src/lib/**
```

---

This document summarizes the secure development lifecycle for the New Coworker platform (newcoworker.com), the application behind the “New Coworker OAuth” Zoom Marketplace app. Full workflow definitions, the merge policy, and the security standards documentation are available for review on request.